# Ready-to-send drafts

**Thirteen drafts cover every planned send to 22 Jan 2027; each is ready once its [placeholders] are filled and the named approver signs it off.**

## Draft index

*Exhibit 12: Drafts, senders, approvers and send windows*

| Draft | Audience | Sender | Approver | Send window | Length |
|---|---|---|---|---|---|
| (a) CEO note after board approval | All employees | CEO | CEO and executive sponsor; General Counsel reviews | Fri 20 Nov 2026 | About 350 words |
| (b) CTO and CISO note | Engineering and product teams | CTO and CISO | Senders and executive sponsor; General Counsel reviews | Mon 23 Nov 2026 | About 650 words |
| (c) Board cover memo | Board of directors | Executive sponsor | Executive sponsor; CFO; General Counsel | Thu 12 Nov 2026, with the pre-read | One page |
| (d) BU cascade talking points and Q&A | BU leadership teams | BU presidents | Executive sponsor; General Counsel reviews the Q&A | Pre-wire 9 to 13 Nov; cascade from 23 Nov 2026 | One page plus five Q&As |
| (e) Product-management briefing | Product managers | Compliance lead | Compliance lead; General Counsel reviews | Mon 9 Nov 2026 (pre-read); PM forum Tue 10 Nov | About 500 words |
| (f) Sales and support briefing; B2B letter; consumer holding line | Sales and support; B2B customers; consumers | Head of customer operations; account owners | General Counsel and executive sponsor | 1 to 3 Dec; 11 Dec; from 1 Dec 2026 | 450, 400 and 80 words |
| (g) Supplier letter and questionnaire email | Top 15 suppliers; all 41 in-scope suppliers | Head of procurement | General Counsel and executive sponsor | Tue 24 Nov 2026 | 450 and 180 words |

| Draft | Audience | Sender | Approver | Send window | Length |
|---|---|---|---|---|---|
| (h) Channel partner letter | Distributors, importers, retail partners | Head of channel | General Counsel and executive sponsor | Thu 10 Dec 2026 | About 500 words |
| (i) Works council information note | Works council | HR business partner for management | General Counsel (employment); executive sponsor | Mon 2 Nov 2026 | About 550 words |
| (j) Intranet article | All employees | Internal communications | Executive sponsor; General Counsel reviews | Fri 20 Nov 2026 | About 500 words |
| (k) Three Teams/Slack posts | All employees; engineering | Internal communications; product security officer | Executive sponsor | 20 Nov, 26 Nov, 11 Dec 2026 | Under 80 words each |
| (l) Notified-body outreach email | Candidate notified bodies | Head of quality & regulatory | General Counsel and executive sponsor | Tue 3 Nov 2026 | About 400 words |
| (m) OSPO note to maintainers | Open-source maintainers | OSPO lead | General Counsel and executive sponsor | Thu 14 Jan 2027 | About 400 words |

Source: Communications calendar (tab 4) and approval matrix (tab 1); Illustrative

Every number in these drafts is as at 30 Oct 2026. Before sending, check it against the latest weekly flash and change it only from that source.

## (a) CEO note to all staff after board approval

- **Subject:** Project Rampart: how we keep our EU market open
- **From / to:** [CEO name], Chief Executive Officer, to all employees
- **Length:** about 350 words; one screen
- **Approver:** CEO and executive sponsor; General Counsel reviews, because the note describes compliance status
- **Send window:** Fri 20 Nov 2026, 08:00 CET, only if BD1 to BD5 are approved as proposed. If not, replace the first paragraph with: ‘Yesterday the Board discussed Project Rampart and asked us to [outcome]. I will update you by [date].’

- **Guidance:** do not mention IR-300 and IS-200 until the affected customers have heard from their account managers (week 11). Keep the budget figure for management audiences.

**Draft**

Dear colleagues,

Yesterday the Board approved Project Rampart, our programme to meet the EU Cyber Resilience Act. I want you to hear from me what it means for Example Group and for you.

The Act makes cybersecurity a condition of selling connected products in the EU, where we earn 69% of our revenue. Two dates matter. Since 11 September 2026 we must report actively exploited vulnerabilities and severe incidents in our products to the authorities within 24 hours, including for products we no longer sell. From 11 December 2027, every product we place on the EU market must meet the Act's security requirements, be backed by evidence and carry CE marking on that basis.

We start from solid ground. We registered for reporting before the duty began, and in our first drill we filed an early warning in 9 hours 40 minutes against a 24-hour limit. The harder part is market access. Seven of our thirteen product families, more than half of our EU revenue, need an independent assessment by a notified body before we can keep selling them, and those bodies are only now being set up. We will book that capacity early.

The Board approved four things that matter to all of us:

- a dedicated programme, funded to December 2027;
- our CTO, [name], as the executive accountable for product cybersecurity, and a rule that I sign each product's EU declaration of conformity, or delegate in writing, only on documented evidence;
- early contracts with independent assessment bodies;
- a clear principle: cost alone is never a reason to leave a product security risk unaddressed.

What this means for you:

- **Everyone:** if you hear of a possible vulnerability or attack on one of our products, tell PSIRT within the hour at [PSIRT contact]. Nobody will be criticised for reporting something that turns out to be nothing.
- **Engineering and product teams:** [CTO name] and [CISO name] will write to you on Monday about the changes to how we build and ship.

- **Sales and support:** you will be briefed in early December. Until then, please do not describe any product as ‘CRA certified’; there is no such certificate.
- **Training** takes place in working time. Find your module at [link].

Security is now part of what we sell. Thank you for making it part of how we work.

[CEO name], Chief Executive Officer

## (b) CTO and CISO note to engineering and product teams

- **Subject:** What changes in how we build and ship: Project Rampart for engineering and product teams
- **From / to:** [CTO name] and [CISO name] to all engineers (920), product managers and release managers
- **Length:** about 650 words
- **Approver:** CTO and CISO; executive sponsor; General Counsel reviews
- **Send window:** Mon 23 Nov 2026, ahead of the engineering all-hands on Thu 26 Nov

**Draft**

Dear colleagues,

On Friday [CEO name] explained why the EU Cyber Resilience Act matters to Example Group. This note sets out what changes for engineering and product teams, and what stays the same.

**Why it matters to engineering.** From 11 December 2027 every product we place on the EU market must meet the Act’s security requirements, and we must prove it for each product version, with records kept for at least ten years. That proof has to come from how we already build: our pipelines, tests and release decisions. If it is not recorded, it did not happen.

**Five changes, in the order you will meet them**

1. **Reporting suspected exploitation: now.** Article 14 has applied since 11 September 2026. If you see evidence that someone is exploiting a vulnerability in one of our products, or an incident that touches product security such as our update service or signing keys, tell PSIRT within the hour on [PSIRT phone] or at [PSIRT email]. Give the product and version, what you saw, when (in UTC) and where the evidence is. Preserve

logs, do not investigate alone, and do not discuss it outside PSIRT, including in tickets and public channels. PSIRT decides when we are ‘aware’, and the 24-hour clock runs from that decision.

2. **A signed SBOM for every release.** Each release carries a software bill of materials generated from the built artefact and signed. Today that is true for 38% of releases (9 of 24 in the last 30 days); the target is 100% by 31 March 2027. HBS firmware builds add binary analysis by 15 January 2027, because manifest-only SBOMs miss vendored code. SBOMs go into our technical documentation; we do not publish them.
3. **A risk assessment and threat model per product.** The T200 pilot assessment is in review. Threat-modelling sprints for the other seven Wave 1 families run from 30 November to 26 February 2027; your product security officer will book your team’s sessions.
4. **A security release gate.** By 22 January 2027 the gate is enforced on the T200 and IR-500 trains; it then rolls out to every Wave 1 train. It checks what you already produce: a signed SBOM, no open high-risk findings, an up-to-date risk assessment and a signed update. The product security officer can block a release. A disagreement goes to the executive sponsor within two working days, and the block stands until it is overturned in writing.
5. **Secure updates.** Update signing moves to a hardware security module and anti-rollback protection lands by 30 June 2027. Security fixes ship on a separate security train wherever that is technically feasible.

**What stays the same.** Much of the security work we already do counts. IC’s IEC 62443-4-1 certified development process and HBS’s EN 18031 assessments are our starting point, not something we discard.

**What we ask of you this month**

- Join the engineering all-hands on Thursday 26 November at [time] ([link]).
- Complete your CRA training. 140 of 920 engineers have done so; we aim for 60% by March 2027. Book at [link]; it takes place in working time.
- Save the PSIRT number in your phone: [number].

We know this adds work to a full 2027 roadmap. The programme funds the remediation time and builds the shared tooling, so that each team does each thing once. Send questions to [Rampart engineering channel] or to your product security officer.

[CTO name], Chief Technology Officer, and [CISO name], Chief Information Security Officer

## (c) Board paper cover memo for 19 Nov 2026

- **Subject:** Project Rampart: five decisions to keep our EU market open
- **From / to:** [Executive sponsor name], on behalf of the Executive Committee, to the Board of Directors
- **Length:** one page, plus the Board briefing deck (D01)
- **Approver:** executive sponsor; CFO (numbers); General Counsel (legal statements); the company secretary issues it
- **Send window:** Thu 12 Nov 2026, with the board pre-read

**Draft**

MEMORANDUM · BOARD CONFIDENTIAL

**To:** Board of Directors, Example Group

**From:** [Executive sponsor name], Executive Sponsor, Project Rampart

**Date:** 12 November 2026 · **Meeting:** Board, 19 November 2026, item [x]

**Decision requested.** Approve decisions BD1 to BD5 so that Example Group can keep selling in the EU after 11 December 2027, 387 days after this meeting.

**Why now**

- The EU Cyber Resilience Act (Regulation (EU) 2024/2847) makes product cybersecurity a condition of EU market access. Reporting of actively exploited vulnerabilities and severe incidents has applied since 11 September 2026 to every product we have sold; all other obligations apply from 11 December 2027.
- Seven of our 13 product families, EUR 468m of EU revenue and 39% of group revenue, need a notified body: Class I families could self-assess only by applying in full a harmonised standard, common specification or ‘substantial’ EU certification scheme (Art 32(2)), none available today, and SG-900 (Class II) always needs third-party assessment. No harmonised standard is cited (30 October 2026), and no CRA notified body was verifiably designated at checks to 8 September 2026. Assessment capacity will be scarce.
- Compliance must be evidenced for each product version and kept for ten years. From 9 December 2026 the Product Liability Directive makes such records disclosable in court.
- The maximum fine for the core obligations is EUR 30m for us (2.5% of EUR 1.2bn turnover). The larger exposure is losing EU market access for products that cannot be assessed in time.

**Where we stand.** Portfolio readiness is 44% (baseline 28 October 2026). Article 14 reporting is our strongest domain at 72%; our first drill filed an early warning in 9h 40m. Conformity and market access is the weakest at 16%, documentation 24%. Class I home products are least ready (L2 35%, V1 38%). Programme status is Amber: reporting on track; market access at risk on an external dependency.

| ID | Decision | What it commits | Why |
|---|---|---|---|
| BD1 | Approve the Project Rampart investment envelope | EUR 9.3m one-off to Dec 2027, including 15% contingency (EUR 1.42m in Q4 2026, EUR 7.83m in 2027), and EUR 1.8m a year to run from 2028 | 0.77% of one year's revenue; scenarios range from EUR 7.9m to EUR 11.4m |
| BD2 | Appoint the accountable executive and execute the DoC signing instrument | CTO accountable; CEO signs declarations of conformity or delegates in writing; the compliance lead counter-signs the pre-signature checklist | The signatory assumes responsibility for each product's compliance |
| BD3 | Authorise notified-body pre-contracting | Pre-assessments with three candidate bodies (up to EUR 60k); formal contracts by Q1 2027: Module H for IC and FleetView, Module B+C for V1 and L2 | Secures scarce capacity against our highest risk, R01 (score 20, rising) |
| BD4 | Adopt the product-risk acceptance rule | Cost, risk appetite and commercial strategy are not grounds to leave product risk unaddressed; appeals go to the executive sponsor | Commission guidance C(2026) 5252 (paras 156-163, non-binding) reads the law this way |
| BD5 | Withdraw IR-300 and IS-200 from EU sale before 11 Dec 2027 | Customers migrate to IR-500 and IS-300 | EUR 18m of declining EU revenue against about EUR 1.4m of remediation plus notified-body fees |

**If we do not decide on 19 November.** Pre-assessment contracts due 29 January 2027 and formal contracts due 31 March 2027 will slip, and both are already At risk. Without them, our seven Class I and II families cannot complete third-party assessment before 11 December 2027 and could not be placed on the EU market from that date.

**Attached.** Board briefing deck, Keeping our EU market open (D01); Business case and cost model (D10); Programme dashboard (D09).

**Next report.** Quarterly board update for Q4 2026, at the [month] 2027 meeting.

[Executive sponsor name], Executive Sponsor, Project Rampart

## (d) BU president cascade: talking points and likely questions

- **From / to:** BU presidents (HBS, IC, S&S) to their leadership teams; the executive sponsor uses the same page in the pre-wire 1:1s
- **Length:** one page of talking points, plus five questions and answers
- **Approver:** executive sponsor; General Counsel reviews the answers
- **Send window:** pre-wire 9 to 13 Nov 2026; cascade meetings from Mon 23 Nov 2026

**Talking points**

1. **What was decided.** On 19 November the Board approved Project Rampart: a 14-month programme to keep our EU market open under the Cyber Resilience Act, funded centrally to December 2027, with the CTO accountable.
2. **Why it matters to our BU.** Use your BU's line:
    - **HBS:** V1 Video Doorbell and L2 Smart Lock are Class I, with EUR 129.5m of EU revenue, and need a notified body under Module B+C. They are our least-ready families (V1 38%, L2 35%). HomeHub H3 is planned as Class I until the legal opinion lands on 27 Nov 2026. T200 is the programme's pilot.
    - **IC:** IR-500, IS-300 and SecureLink (Class I) and SG-900 (Class II) carry EUR 306.9m of EU revenue. Module H, built on our IEC 62443-4-1 process, covers them with one body. EG-700 is planned as Class I until the legal opinion lands. IR-300 and IS-200 leave EU sale before 11 Dec 2027 (BD5).
    - **S&S:** FleetView (Class I, EUR 31.9m of EU revenue) joins IC's Module H route. ConfigStudio and the IoT SDK self-assess under Module A. Our cloud platform counts as part of the products that depend on it.

3. **Reporting is already live.** Every product we have sold, including discontinued lines, is on a 24-hour reporting clock. Our first drill filed in 9h 40m. Everyone in the BU should know how to reach PSIRT within the hour.
4. **The constraint is outside our control.** No CRA notified body was verifiably designated at checks to 8 Sep 2026, and no harmonised standard is cited. We are pre-contracting three candidates; slots will go to manufacturers who are ready early.
5. **What I need from you.** Ring-fence the remediation engineers in your 2027 plan; two roadmap features move to make room ([features]). Make support-period and Annex II decisions with product management on time. Protect training time: 60% of engineers trained by March 2027. Back the release gate: a block stands until it is overturned in writing.
6. **What to say to customers.** 'We are preparing every product family to meet the CRA by 11 Dec 2027.' Never 'CRA certified'. The customer FAQ goes live on 8 Dec 2026.

**Five likely questions**

1. **Will this delay our 2027 roadmap?** In part. Remediation needs 26.2 FTE-years across the portfolio and competes with roadmap work for the same engineers. The plan ring-fences that capacity, defers two roadmap features and uses contractors for documentation and testing. Each BU review shows the trade-off.
2. **Why can't we self-assess, as we do for CE marking today?** Four default families can, under Module A; EG-700 and HomeHub H3 join them only if the 27 Nov legal opinion confirms default class. A Class I product may self-assess only by applying in full a cited harmonised standard, a common specification or a 'substantial' EU certification scheme (Art 32(2)), and none is available as at 30 Oct 2026; a Class II product always needs a third party. Our seven important families therefore plan on a notified body and switch to Module A only if a standard is cited in time.
3. **What if no notified body is ready in time?** That is our highest risk (R01). We are pre-contracting three candidates with options to convert to formal engagements; one Module H approval covers five IC and S&S families; complete Module A records keep the fallback open; and we prioritise the highest-revenue SKUs. A Class I or II product that cannot be assessed cannot be placed on the EU market from 11 Dec 2027, and the Board sees this position every quarter.
4. **Does this affect products customers already have?** Reporting does: since 11 Sep 2026 it covers every product we have placed on the EU market, including the T100 thermostat with 1.1m units in the field. The new design requirements apply to units placed on the market from 11 Dec 2027, so units already sold need no retrofit unless we substantially modify them.

5. **Who pays?** The central envelope of EUR 9.3m to December 2027 includes EUR 3.14m for engineering remediation (26.2 FTE-years). The engineers are yours, so the capacity must be in your 2027 plan. Running costs from 2028 are EUR 1.8m a year; [the CFO confirms the BU allocation].

## (e) Product-management briefing

- **Subject:** CRA decisions that belong to product management
- **From / to:** [Compliance lead name] to all product managers, as the pre-read for the PM forum
- **Length:** about 500 words; a 15-minute forum slot
- **Approver:** compliance lead; General Counsel reviews
- **Send window:** Mon 9 Nov 2026 as a pre-read; discussed at the PM forum on Tue 10 Nov

**Draft**

**Your decisions now carry legal weight.** Under the Cyber Resilience Act, three product-management decisions become part of each product's compliance record: the support period, the security information that ships with the product, and where we sell it.

**1. Support period: confirm by [date].** The support period is how long we handle vulnerabilities and provide security updates. The law sets it from the time the product is expected to be in use: at least five years, unless the product is expected to be used for less (Art 13(8)). Commission guidance treats five years as a floor, not a default (paras 125-128), and Recital 60 names routers and industrial control systems among products used for longer. From 11 December 2027 the end month and year must be shown at purchase (Art 13(19)). Confirm or change each planning assumption below with a written rationale.

| Family | Planned support period (years) |
|---|---|
| IR-500 Industrial Router; IS-300 Managed Switch | 12 |
| T200 Smart Thermostat; L2 Smart Lock; EG-700 Edge Gateway; SG-900 Industrial Firewall/IDS | 10 |
| S-Series Room Sensors | 8 |
| HomeHub H3; V1 Video Doorbell; SecureLink Remote Access | 7 |

| Family | Planned support period (years) |
|---|---|
| FleetView Device Manager; ConfigStudio; Example IoT SDK | 5 |

Source: Project Rampart product register, 30 Oct 2026; Illustrative

**2. Annex II user information: template by 18 December 2026, T200 first.** Every product ships with security information: our contact details, the vulnerability contact and disclosure policy, intended use and foreseeable misuse, the support end date, how to install updates and how to switch off automatic updates, secure decommissioning, and where to find the declaration of conformity. The technical writing lead drafts it; you own the content.

**3. Where we sell: refresh by 20 November 2026.** The early warning we file within 24 hours must list the Member States where the product is available. In our 22 October drill we could not complete that field for two products from current data. Refresh the distribution map for your products by 20 November and keep it current.

**4. What counts as the product.** Companion apps, and the backends we build that a product needs in order to work, are part of that product. Flag any new app, cloud function or version in the scope register when you plan it, not when you ship it.

**5. Trade-offs.** Remediation competes with the 2027 roadmap for the same engineers, and two roadmap features are being deferred ([features]). Subject to the board decision on 19 November, cost, risk appetite or commercial strategy will no longer justify leaving a product security risk unaddressed; the design or the feature may have to change instead.

**Legacy lines.** Reporting covers products we no longer sell, and after their support ends. Keep end-of-support statements accurate: HomeHub H2 security fixes end in December 2026, FleetView 4.x support ends in December 2026, and SecureLink 3.x support ends in June 2027.

**Your asks.** Confirm support periods by [date]. Refresh the distribution map by 20 November. Name a reviewer for your family's Annex II draft by [date]. Attend PM forum #2 on 19 January 2027.

[Compliance lead name], Compliance Lead, Project Rampart

# (f) Sales and support briefing, B2B customer letter and consumer holding line

## (f1) Sales and support briefing note

- **From / to:** [Head of customer operations] to sales, key-account and customer-support staff
- **Length:** about 450 words; used in a 30-minute live session and the two-hour LMS module
- **Approver:** General Counsel and executive sponsor (describes compliance status)
- **Send window:** live sessions Tue 1 to Thu 3 Dec 2026

**Draft**

**What the CRA is.** An EU law that makes cybersecurity a condition of selling connected products in the EU. Reporting of actively exploited vulnerabilities and severe incidents has applied since 11 September 2026; everything else applies from 11 December 2027.

**What we are doing.** Project Rampart prepares every product family to meet the Act by 11 December 2027. We registered for reporting before the duty started and tested it in a drill on 22 October 2026.

**What customers will get, and when**

- A vulnerability contact and disclosure policy for every business unit (HBS and S&S from 4 December 2026).
- Security advisories in human-readable and machine-readable (CSAF) form.
- Support periods per product, published on the trust page by [date].
- An SBOM on request for B2B customers, under [terms].
- An EU declaration of conformity and CE marking for each product before 11 December 2027, on a published timetable.

**Say:** ‘We are preparing every product family to meet the CRA by 11 December 2027.’ **Don’t say:** ‘CRA certified’, ‘fully compliant’, or any product date not yet on the trust page. Tab 3 has the full list.

**Questionnaires.** Answer only from the customer FAQ and our published material. Send anything else to [CRA questions mailbox]; the programme replies within [5] working days. An improvised answer that later reaches an authority can itself become a compliance problem.

**If a customer reports a vulnerability or a possible attack.** Thank them; record the product, version, what they saw and when; pass it to PSIRT within the hour at [PSIRT contact]. Do not confirm, deny or speculate, and do not promise a fix date. PSIRT will contact the customer.

**During an incident.** Use only the holding statement PSIRT issues (tab 7), and log every customer contact in [CRM field].

**Training.** Complete the LMS module at [link] by [date].

## (f2) B2B customer letter

- **Subject:** Example Group and the EU Cyber Resilience Act: what you will receive from us, and when
- **From / to:** account owner, signed by [Head of customer operations or BU president], to each B2B customer and integrator
- **Length:** about 400 words; one page
- **Approver:** General Counsel and executive sponsor
- **Send window:** Fri 11 Dec 2026, three days after the customer FAQ goes live

**Draft**

Dear [customer contact name],

The EU Cyber Resilience Act (Regulation (EU) 2024/2847) applies in full one year from today, on 11 December 2027. Many of you have asked what it means for the Example Group products you buy and integrate, and for your own obligations under NIS2 and the Act. This letter answers that.

**What already applies.** Since 11 September 2026 manufacturers must report actively exploited vulnerabilities and severe incidents affecting their products to EU authorities within 24 hours. We registered on ENISA's Single Reporting Platform before that date, and our product security incident response team (PSIRT) covers every product we have sold, including discontinued lines.

**What we are doing by 11 December 2027.** Through a dedicated programme we are preparing every product family to meet the Act in full: security built into design and development, a software bill of materials for every release, signed and secure updates, and documented evidence for each product version. Products in the categories the Act lists as important will be assessed by an independent notified body; we have engaged candidate bodies early.

**What you will receive**

- A vulnerability contact and disclosure policy at [security page], with security.txt on our websites.
- Security advisories in human-readable form and as machine-readable CSAF documents at [advisory page].
- The end date of security support for each product, published at [trust page] by [date].
- A software bill of materials on request, under [terms]. The Act does not require SBOMs to be public.
- An EU declaration of conformity and CE marking for each product before 11 December 2027, on a timetable published at [trust page].
- Answers to CRA and NIS2 supply-chain questionnaires from our published material: please send them to [address].

**What we ask of you.** Report any vulnerability you find in our products to [PSIRT contact]. Keep automatic security updates enabled where your operations allow, or tell us how you manage updates so that we can reach you quickly.

Our customer FAQ at [link] answers the most common questions, and [account manager name] is available to discuss your situation.

Yours sincerely,

[Name], [Title], Example Group

## (f3) Consumer holding line

- **Use:** customer support, social media replies and retail staff, when a consumer asks about the CRA or product security
- **Length:** about 80 words
- **Approver:** General Counsel and executive sponsor; marketing confirms the per-product facts
- **Window:** from Tue 1 Dec 2026

**Draft**

The EU Cyber Resilience Act sets security rules for connected products sold in the EU. We are preparing all our products to meet it by 11 December 2027, and we report serious security issues to EU authorities whenever the law requires. Your [product] receives

security updates [automatically / through the app]; please keep automatic updates switched on. [Security updates for this product are provided until [month year].] To report a security problem, visit [link].

## (g) Supplier letter and questionnaire cover email

### (g1) Formal supplier letter (wave 1: top 15 security-relevant suppliers)

- **Subject:** CRA commitments for [supply agreement reference]
- **From / to:** [Head of procurement name], [optional: co-signed by the CTO], to the supplier's [contract owner]
- **Length:** about 450 words, plus the enclosed clause pack
- **Approver:** General Counsel and executive sponsor
- **Send window:** Tue 24 Nov 2026; agreement in principle by [18 Dec 2026]; signed amendment by 29 Jan 2027
- **Guidance:** a supplier that refuses a clause is not threatened; procurement records the gap, and the component enters the intake gate as high risk with an exit plan.

**Draft**

Dear [supplier contact name],

Example Group manufactures connected products for the EU market, and the components you supply are part of them. Under the EU Cyber Resilience Act (Regulation (EU) 2024/2847), which applies in full from 11 December 2027, we are responsible for the cybersecurity of every component we ship, and we must evidence it for each product version for at least ten years. We can only do that with your help.

We are therefore asking our security-relevant suppliers, including you, to agree the commitments below through an amendment to our [master agreement]. The full clause pack is enclosed.

1. **Vulnerability notification.** Tell us without undue delay about vulnerabilities in what you supply, through [named channel], with the affected versions and any available fix. If a vulnerability is being actively exploited, tell us at once: our own deadline for reporting to EU authorities is 24 hours.
2. **Software bill of materials.** Provide a machine-readable SBOM with each delivered release, in CycloneDX 1.6 or later or SPDX 3.0.1 or later, with the fields set out in BSI TR-03183-2 and any known unknowns declared.

3. **Support period.** Declare the support period for each component version, give us at least [12] months' notice before it ends, and provide security updates throughout it.
4. **Evidence on request.** Give us access, on request, to your declaration of conformity, relevant extracts of your technical documentation, test reports and risk assessment, including when an authority makes a reasoned request to us.

The pack also covers disclosure coordination, end-of-life notice, cooperation with authorities, traceability, fix sharing for open-source components and notice before ceasing operations.

**Next steps.** Please confirm agreement in principle by [18 December 2026] and return the signed amendment by 29 January 2027. [Procurement contact name] will call you in the next two weeks to walk through the clauses. If a clause does not fit your business, tell us why: we would rather adapt a clause than lose a good supplier, but we must record any gap in our own risk assessment.

You will also receive our supplier questionnaire, which helps us assess each component by its risk.

Yours sincerely,

[Name], Head of Procurement, Example Group

## (g2) Questionnaire cover email (all 41 in-scope suppliers)

- **Subject:** Example Group supplier questionnaire on the EU Cyber Resilience Act: please reply by [date]
- **From / to:** [Head of procurement name] to the named contact at each in-scope supplier
- **Length:** about 180 words
- **Approver:** General Counsel and executive sponsor
- **Send window:** Tue 24 Nov 2026; all 41 sent by 18 Dec 2026
- **Instrument:** Supplier CRA readiness questionnaire in Survey and Interview Instruments (D07)

**Draft**

Dear [name],

As part of our preparation for the EU Cyber Resilience Act, we ask every supplier of components in our products to complete a short questionnaire: [link].

- 31 questions in eight sections: identity and role, conformity, vulnerability handling, SBOM, support, secure development, incident and reporting posture, and evidence available on request.
- About 40 minutes. You can save your answers and finish later.
- Please reply by [date].

We assess each component by its risk, not against a fixed pass mark. There are no wrong answers, and 'not yet' is a useful answer when it comes with a date.

Questions to [procurement contact]. Thank you for your help.

[Name], Head of Procurement, Example Group

## (h) Distributor, importer and retail partner letter

- **Subject:** Selling Example Group products under the EU Cyber Resilience Act: what you will receive and what you need to check
- **From / to:** [Head of channel name] to distributors, importers and retail partners
- **Length:** about 500 words
- **Approver:** General Counsel and executive sponsor
- **Send window:** Thu 10 Dec 2026, with the partner portal page live
- **Guidance:** the IR-300 and IS-200 paragraph goes only to partners who sell those lines, and only after the affected customers have been told.

**Draft**

Dear [partner name],

From 11 December 2027 the EU Cyber Resilience Act (Regulation (EU) 2024/2847) applies in full to connected products sold in the EU, with defined duties for manufacturers, importers and distributors. This letter sets out what we will provide for every Example Group product and what the Act asks of you, so that you can plan.

**What you will receive from us.** For each product, as each family completes and by 3 December 2027 at the latest:

- the EU declaration of conformity, or a simplified declaration giving the web address of the full text;
- CE marking on the product, or on its packaging and documents where the product cannot carry it;

- the security information for users: our contact details, the vulnerability contact, the end date of security support (month and year), how to install security updates and how to use the product securely;
- our name, address and contact details, and type, batch or serial identification, on the product or its packaging;
- a compliance page per product on [partner portal] that holds all of the above.

**What the Act asks of you.** This is a summary; please take your own legal advice.

- **As a distributor** (Art 20), you act with due care. Before you make a product available, you check that it bears the CE marking and that we, and any importer, have supplied the required identification and user information. You do not supply a product you believe does not conform, and you tell us without undue delay about any vulnerability you learn of.
- **As an importer** (Art 19), where you place on the EU market a product made outside the EU, you also verify that the conformity assessment was carried out, that technical documentation exists, and that the declaration and user information accompany the product. You add your own name and contact details, and keep the declaration for ten years or the support period, whichever is longer.
- **If you rebrand or modify a product.** Placing a product on the market under your own name or trademark, or substantially modifying it, makes you its manufacturer, with all the manufacturer's obligations (Art 21). Please talk to us first.

**Stock and timing.** Units we supply to you before 11 December 2027 are placed on the market before the Act's product requirements apply, and you may continue to sell them after that date unless they are substantially modified. Our reporting duty covers them, and we continue to handle vulnerabilities for them.

[Optional, subject to the board decision: IR-300 and IS-200 will not be supplied for EU sale after [date]. Your account manager will discuss migration to IR-500 and IS-300.]

**What we ask of you now**

1. Send vulnerability reports about our products to [PSIRT contact] without undue delay; within one working day is our request.
2. Name a contact for CRA matters by [date] through [partner portal form].
3. Keep our documentation with each product you resell.

Our FAQ at [link] answers common questions. For anything else, contact [channel contact].

Yours sincerely,

[Name], Head of Channel, Example Group

## (i) Works council information note: PSIRT 24/7 on-call and training

- **Subject:** Information on 24/7 on-call for the product security incident response team (PSIRT) and on CRA training
- **From / to:** [HR business partner name], on behalf of management, to the [works council body]
- **Length:** about 550 words; formal written note
- **Approver:** General Counsel (employment law) and executive sponsor
- **Send window:** Mon 2 Nov 2026, with the first consultation meeting; agreement targeted for 18 Dec 2026
- **Guidance:** HR and legal insert the applicable consultation provisions. Figures in [brackets] are proposals for negotiation, not decisions.

**Draft**

Information note to the [works council body], [2 November 2026]

**Purpose.** Management informs the works council of two measures needed to meet the EU Cyber Resilience Act, and opens consultation on them [under the applicable provisions]: 24/7 on-call for the product security incident response team (PSIRT), and role-based CRA training.

**1. Why the measures are needed.** Since 11 September 2026 the Act has required Example Group to report any actively exploited vulnerability or severe incident affecting its products to EU authorities within 24 hours of becoming aware of it, on any day of the year. Today two people hold most of PSIRT's knowledge. That is not sustainable for the business, and it is not fair on them.

**2. Proposed on-call arrangement**

- **Voluntary.** Places on the rota are filled by volunteers from PSIRT and from trained engineers; nobody is required to join.
- **Rota.** [One week in n], with at least [n] people, so that no one is on call for more than [one week in four].
- **What on-call means.** Reachable by phone within [30] minutes, with no obligation to be on site, and able to reach a registered reporting representative within one hour.

- **Pay and rest.** An on-call allowance of [amount] per [week]; time worked during a call-out [paid as overtime or compensated with time off]; rest periods after a call-out respected in line with [working-time rules].
- **Equipment.** A company phone, laptop and security key.
- **Authority and protection.** The PSIRT lead or a named deputy decides when the company is ‘aware’ and may file the 24-hour early warning without prior approval. Nobody is disciplined for a decision taken in good faith.

**3. Records and monitoring.** The law requires us to evidence the timeline of every case. Case records will therefore show who handled a case, when (in UTC) and what was decided, and will be kept for at least 10 years or the product’s support period, whichever is longer. Management proposes that on-call and case records are not used to assess individual performance or behaviour, that access is limited to PSIRT, compliance and legal, and that the data protection officer reviews the arrangement. [Data protection notice: link.]

**4. Training.** All CRA training takes place in working time and is role based.

| Role | Training |
|---|---|
| Executives and board | 90 minutes at programme start; annual refresh |
| Engineering leads, developers and product managers | Half a day; refreshers through the release gate and annually |
| PSIRT | One full day at appointment; two drills a year; monthly case review |
| Procurement and legal | Half a day |
| Sales and support | Two hours; refresher when incident templates change |

So far 140 of 920 engineers have completed training; the target is 60% by March 2027. Training records are kept as evidence of competence, which notified bodies may review.

**5. Timetable.** Consultation meeting on [date]; works council questions by [date]; management’s written response within [5] working days; agreement targeted for 18 December 2026.

**Contact.** [HR business partner name], [phone], [email].

## (j) Intranet article

- **Headline:** Project Rampart: keeping our EU market open
- **Length:** about 500 words; one image slot for the CRA on a page visual (D04)
- **Approver:** executive sponsor; General Counsel reviews
- **Publish:** Fri 20 Nov 2026, linked from the CEO note; refresh after each milestone

**Draft**

*The EU Cyber Resilience Act makes cybersecurity a condition of selling connected products in Europe. Here is what it means for Example Group, what the Board decided on 19 November, and what you need to do.*

**A law about products, not just IT.** The Cyber Resilience Act (Regulation (EU) 2024/2847) sets security rules for every connected product sold in the EU, from our thermostats and doorbells to our industrial routers, firewalls and software. It entered into force in December 2024 and applies in two steps.

**Step one is already live.** Since 11 September 2026 we must report any actively exploited vulnerability or severe incident affecting one of our products to EU authorities within 24 hours of becoming aware of it, with a fuller notification at 72 hours and a final report later. This covers every product we have sold, including lines we no longer make. Our product security incident response team (PSIRT) registered on the EU's reporting platform before the deadline and, in a drill on 22 October, filed an early warning in 9 hours 40 minutes.

**Step two arrives on 11 December 2027.** From that date every product we place on the EU market must meet the Act's security requirements: secure by design and by default, with free security updates for a declared support period of at least five years unless the product is expected to be used for less, a software bill of materials, and a technical file for each version. Each product then carries CE marking on the basis of an EU declaration of conformity.

**Why it matters so much to us.** About 69% of our revenue comes from the EU. Seven of our thirteen product families fall into categories the Act treats as 'important', and they need an independent assessment by a notified body before we can keep selling them after December 2027. Those bodies are only now being set up, so capacity will be tight.

**What the Board decided.** On 19 November the Board approved Project Rampart, a 14-month programme in three waves. It builds shared capabilities once, such as our SBOM pipeline, secure update infrastructure and evidence system, applies them product by product, and books assessment capacity early. The CTO is accountable, and the CEO signs each declaration of conformity, or delegates in writing, on documented evidence.

**What happens next.** By the end of 2026 we aim to have agreed 24/7 on-call arrangements for PSIRT with the works council, published our vulnerability disclosure policy across all business units and completed our product scope register. In 2027 product teams carry out risk assessments, close gaps and assemble technical files, so that declarations can be signed before 11 December 2027.

**What you need to do**

- If you hear of a possible vulnerability or attack on one of our products, tell PSIRT within the hour: [PSIRT contact].
- Complete the CRA training for your role at [link]; it takes place in working time.
- If a customer asks about the CRA, use the customer FAQ at [link], and never describe a product as ‘CRA certified’: there is no such certificate.

**Find out more:** the staff FAQ at [link], the Rampart channel at [link], or write to [programme mailbox].

## (k) Three Teams/Slack posts

- **Approver:** executive sponsor; the CTO also approves post 2
- **Length:** under 80 words each; one link per post, plus the PSIRT contact

**Post 1: launch.** Fri 20 Nov 2026, all-staff channel, from internal communications

Project Rampart is go. Yesterday the Board approved our programme to meet the EU Cyber Resilience Act. One thing everyone can do today: save the PSIRT contact, [contact]. If you hear of a possible vulnerability or attack on one of our products, tell PSIRT within the hour. Read [CEO name]’s note and the full story here: [intranet link]. Questions: [channel].

**Post 2: engineering all-hands.** Thu 26 Nov 2026, engineering channels, from the product security officer

Engineering all-hands today at [time]: what the CRA changes in how we build and ship. On the agenda: the release gate on the T200 and IR-500 trains by 22 Jan, a signed SBOM on every release by 31 Mar 2027 (38% today), and how to report suspected exploitation. Join: [link]. Slides and recording afterwards in [channel]. Book your CRA training: [link].

**Post 3: one year to go.** Fri 11 Dec 2026, all-staff channel, from internal communications

One year to go: on 11 Dec 2027 the EU Cyber Resilience Act applies in full. Reporting already applies, so if you hear of a possible vulnerability or attack on one of our products, tell PSIRT within the hour at [contact]. Our vulnerability disclosure policy is now live for every business unit: [link]. Customer asking about the CRA? Use the FAQ: [link].

## (1) Outreach email to a candidate notified body

- **Subject:** Request for a CRA pre-assessment proposal: Example Group (Module H and Module B+C)
- **From / to:** [Head of quality & regulatory name] to [named contact] at each candidate body
- **Length:** about 400 words, including the scope table
- **Approver:** General Counsel and executive sponsor
- **Send window:** Tue 3 Nov 2026 to the two candidates yet to propose; proposals by [4 Dec 2026]
- **Guidance:** sign a non-disclosure agreement before sharing technical documents. Do not mention our budget (BD3 caps pre-assessments at EUR 60k across three bodies).

**Draft**

Dear [name],

Thank you for [our conversation on date / your presentation at event]. Example Group, a German-headquartered manufacturer of connected home, building and industrial products, is preparing 13 product families for the Cyber Resilience Act (Regulation (EU) 2024/2847). Seven fall into Annex III categories, and we want to secure assessment capacity early.

We would welcome your proposal for a pre-assessment on the following scope.

| Route | Families | Annex III category | Starting point |
|---|---|---|---|
| Module H (full quality assurance) | IR-500 Industrial Router, IS-300 Managed Switch, SecureLink Remote Access, FleetView Device Manager (Class I); SG-900 Industrial Firewall/IDS (Class II) | Class I items 12, 5 and 6; Class II item 2 | Development process certified to IEC 62443-4-1 (2024) |
| Module B+C (type examination and production control) | V1 Video Doorbell; L2 Smart Lock (Class I) | Class I item 17 | EN 18031-1 assessments under the RED delegated act (2025) |

[Optional: two further families, EG-700 Edge Gateway and HomeHub H3, may join this scope, depending on a classification opinion due on 27 Nov 2026.]

Please cover in your proposal:

1. the accreditation you are seeking (EN ISO/IEC 17065, 17021-1 or both), your notifying authority and your expected notification date;
2. the Annex III categories you intend to cover;
3. the scope, method, duration and fees of a pre-assessment on one representative product per route;
4. an option to convert the pre-assessment into a formal Module H or Module B engagement once you are notified, with indicative lead times, surveillance terms and fees;
5. how you would handle substantial modifications, and how you treat draft standards as evidence;
6. transition terms if your notification is delayed, including return of documentation and release from exclusivity;
7. confidentiality terms and any subcontracted testing.

We understand that a pre-assessment is not a conformity assessment under Article 32, and we will record it as such.

We would be grateful for your proposal by [4 December 2026] and would welcome a call in the week of [date].

Kind regards,

[Name], Head of Quality & Regulatory, Example Group

## (m) OSPO note to open-source maintainers

- **Title:** How Example Group will report vulnerabilities upstream under the Cyber Resilience Act
- **From / to:** [OSPO lead name], published on [open-source page] and sent to the maintainers of [critical dependencies] through their preferred channels
- **Length:** about 400 words
- **Approver:** General Counsel and executive sponsor
- **Send window:** Thu 14 Jan 2027
- **Guidance:** never attach a questionnaire, contract or SBOM request to this note.

**Draft**

Dear maintainers,

Example Group builds connected products with open-source software, and we are grateful for the work behind it. The EU Cyber Resilience Act (CRA) places duties on manufacturers like us. This note explains what that means for how we work with you, and what it does not mean.

**The duties are ours, not yours.** As the manufacturer, we are responsible for the security of every component we ship, open source included (Art 13(5)). Using your project does not transfer that responsibility to you. We will not send you compliance questionnaires, ask you for attestations or SBOMs, or ask you to accept contract terms because of the CRA.

**How we will report vulnerabilities to you.** The CRA asks manufacturers to report vulnerabilities they find in components to the people who maintain them, and to share any fix (Art 13(6)). That duty applies from 11 December 2027; we are adopting the practice now.

1. We check first whether you already know about the issue (advisories, vulnerability databases, your issue tracker) and report only if you do not.

2. We report through your published channel, such as SECURITY.md, security.txt or private advisories, and never in a public issue while a vulnerability is unfixed.
3. We report for the version we integrate, with what we know: affected versions, reproduction details and our assessment.
4. If we develop a fix, we offer it in a form you can review, under your licence and following your contribution guidelines. Whether you accept it is your decision; any local patch remains our responsibility.
5. We follow your disclosure policy and embargoes. If a vulnerability is actively exploited in one of our products, we must report it to EU authorities within 24 hours; we will tell you promptly and agree with you what we disclose.

**What you can expect from us.** A named contact at [OSPO email], credit where you want it, and [our contribution to your project's security work, for example engineering time or funding].

If you are considering your own position under the CRA, the Open Regulatory Compliance working group and the OpenSSF publish community guidance for maintainers and stewards: [links].

Thank you,

[Name], Open Source Program Office lead, Example Group

*Project Rampart · Communication Pack (D05) · Illustrative · v1.0 · 31 Oct 2026*